

TP 2 : méthode de reconnaissance passive

TP 2 · Reconnaissance passive

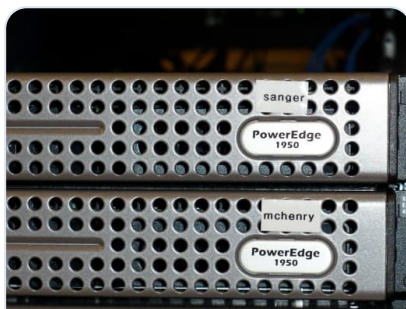


MATÉRIEL QUE TU CROISES DANS CE LABORATOIRE



Ordinateur portable

L'ordinateur que l'on emporte partout



Serveur

Fournit fichiers, messagerie ou site web aux autres

Photos issues de Wikimedia Commons : Ordinateur portable, Ahunt, CC0 · Serveur, Florence Devouard, CC BY-SA 4.0.

À RETENIR

- ◆ Cadre et limites : tu analyses uniquement des sources publiques fournies par le labo. Ne touche jamais un système réel sans autorisation écrite.
- ◆ Les exemples ci-dessous utilisent des valeurs inventées, pas celles du scénario.

1 Lire les sources sans les mélanger

Le DNS public montre des noms et des types d'enregistrements. Un journal de transparence des certificats montre des noms observés dans des certificats publics. Un export WHOIS ou RDAP renseigne le titulaire et le registrar. Des pages publiques et des annonces d'emploi montrent parfois des indices de pile technique.

2 Rappel utile sur les types DNS

- ◆ A : nom vers IPv4.
- ◆ AAAA : nom vers IPv6.
- ◆ MX : serveur de courrier avec une priorité numérique ; la plus basse passe en premier.
- ◆ TXT : texte libre. SPF, DKIM et DMARC y apparaissent souvent.
- ◆ CNAME : alias vers un autre nom.
- ◆ TTL : durée de mise en cache en secondes.
- ◆ Un nom qui porte un CNAME ne doit pas porter d'autre donnée au même owner name ; on l'interprète donc comme un alias et non comme un ensemble d'enregistrements cumulables.

Un nom peut apparaître dans plusieurs sources. Quand une question parle d'union d'ensembles, tu comptes ce nom une seule fois même s'il revient plusieurs fois.

3 Ce qu'apporte la transparence des certificats

Une observation CT est une preuve directe qu'un nom a été inscrit dans un certificat public. Cela ne garantit pas que le nom répond aujourd'hui, mais cela suffit pour le noter dans un inventaire passif.

4 Visionneuse du site

Dans la visionneuse, commence par chercher un nom, un type DNS ou un mot métier. Garde un bloc-notes avec quatre colonnes simples : source, nom, indice, commentaire. Évite de conclure trop vite à partir d'une seule source.

5 Exemple Bash sur des données inventées

BASH

```
cat > guide-dns-exemple.csv <<'EOF'
name,type,value ttl
www.violette.example,A,192.0.2.10,3600
mail.violette.example,MX,10 smtp.violette.example,3600
violette.example,TXT,v=spf1 include:smtp.violette.example -all,3600
EOF
cat > guide-ct-exemple.jsonl <<'EOF'
{"commonName":"www.violette.example","san":["www.violette.example","teletravail.violette.example"]}
{"commonName":"docs.violette.example","san":["docs.violette.example"]}
EOF
{
  tail -n +2 guide-dns-exemple.csv | cut -d, -f1
  grep -o '"[a-z0-9.-]*\.violette\.example"' guide-ct-exemple.jsonl | tr -d '"'
} | sort -u | wc -l
```

6 Exemple PowerShell 5.1 sur des données inventées

POWERSHELL

```
@'
name,type,value,ttl
www.violette.example,A,192.0.2.10,3600
mail.violette.example,MX,10 smtp.violette.example,3600
violette.example,TXT,v=spf1 include:smtp.violette.example -all,3600
'@ | Set-Content -Encoding UTF8 guide-dns-exemple.csv

@'
{"commonName":"www.violette.example","san":["www.violette.example","telettravail.violette.example"]}
{"commonName":"docs.violette.example","san":["docs.violette.example"]}
'@ | Set-Content -Encoding UTF8 guide-ct-exemple.jsonl

$dnsNames = Import-Csv -Path guide-dns-exemple.csv | ForEach-Object { $_.name }
$ctNames = Get-Content -Encoding UTF8 guide-ct-exemple.jsonl | ForEach-Object { $o = $_ | ConvertFrom-Json;
@($o.commonName) + $o.san }
($dnsNames + $ctNames | Sort-Object -Unique).Count
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

7 Repérer SPF, DKIM et DMARC

BASH

```
cat > guide-txt-exemple.csv <<'EOF'
name,type,value
violette.example,TXT,v=spf1 include:smtp.violette.example -all
_dmarc.violette.example,TXT,v=DMARC1; p=quarantine
selector1._domainkey.violette.example,TXT,v=DKIM1; k=rsa; p=demo
www.violette.example,TXT,site-verification=ok
EOF
tail -n +2 guide-txt-exemple.csv | awk -F, '$2 == "TXT" && ($1 ~ /_dmarc/ || $1 ~ /_domainkey/ || $3 ~ /^v=spf1/) { count++
} END { print count }'
```

Commande longue, coupée par la mise en page : copie-la en une seule ligne ou utilise la version texte indiquée en fin de document.

8 Croiser pages et annonces

Pour les pages publiques, compte seulement la colonne de technologie ou le champ dédié. Un témoignage ou une citation de migration dans un paragraphe n'est pas une preuve de technologie en production. Pour les annonces, lis les lignes structurées avant les notes en prose.

9 Exemple PowerShell 5.1 pour la techno la plus citée

POWERSHELL

```
@'
{"url":"https://www.violette.example/","technology":"astro"}
{"url":"https://docs.violette.example/","technology":"astro"}
{"url":"https://status.violette.example/","technology":"haproxy"}
'@ | Set-Content -Encoding UTF8 guide-pages-exemple.jsonl

Get-Content -Encoding UTF8 guide-pages-exemple.jsonl | ForEach-Object { ($_ | ConvertFrom-Json).technology } |
Group-Object | Sort-Object Count -Descending | Select-Object -First 1 | ForEach-Object { $_.Name }
```

10 À retenir

Une bonne reconnaissance passive collecte peu mais relit bien. Tu distingues les sources, tu expliques ta règle de comptage, tu gardes les preuves directes et tu t'arrêtes avant toute interaction active.



Pingo veille sur ta progression

Retourne au laboratoire pour valider tes réponses. Bloqué ? Ouvre d'abord l'indice de la tâche, la correction vient ensuite. Pour copier les commandes sans coupure de ligne, ouvre la [version texte](#).